

Incident Response Plan

(insert company name here)

Version (add number)

Effective Date: (add the date when the plan is adopted)

Last Revision Date: (add the date of the last revision of the document)

Table of Contents

1. INTRODUCTION TO INCIDENT RESPONSE PLAN	3
Purpose	3
Applicability	3
Policy Statement	4
Roles and Responsibilities	5
Members of the Incident Response Team	7
2. INCIDENT DEFINITION AND CLASSIFICATION	8
Incident Definition	8
Reporting	9
Internal Notification	10
Notification to Regulatory and Law Enforcement Agencies	10
Affected Customers	10
Content of Customer Notice	10
Incident Lifecycle	11
Prioritization	12
Evidence	12
Information Sharing	12
3. INCIDENT RESPONSE TESTING	13
Lessons Learned	13
Tabletop Exercises	13
GLOSSARY	14
PLAN MAINTENANCE / DISTRIBUTION	14

1. INTRODUCTION TO INCIDENT RESPONSE PLAN

Purpose

This policy gives (insert company name here) instructions on how to manage information security-related incidents (including cyber events) efficiently and effectively so that it can minimize loss and destruction, mitigate weaknesses, restore services, and notify employees and customers as required by state law. Our commitment is to safeguard (insert company name here)'s information assets and personal data of its workers, partners, and customers.

The objectives of this policy are:

- To make it mandatory to design and maintain an Incident Response Plan (IRP) for (insert company name here);
- To create the framework for a coordinated and successful response and integrated efforts of awareness and communication if a security event occurs;
- To define mitigation and remediation strategies necessary for safeguarding and restoring data, customers, brand, reputation, and financial status for (insert company name here) after a security incident;
- Make a connection between this plan and other (insert company name here) plans and policies.

Applicability

This Incident Response Plan applies to all information assets under the ownership of (insert company name here). Assets not under the exclusive ownership of (insert company name here) may be subject to a subset of this policy — such as cloud assets or other shared infrastructure.

The term “information security incident” is defined as any adverse event that threatens the confidentiality, integrity, or availability of business information.

Some possible scenarios for information security incidents are:

- Unauthorized access, attempted or successful, to a system or data stored on a system;
- Disruption or denial-of-service;

- Theft or loss of a device containing confidential customer information;
- Virus, ransomware, or other types of malicious code infection;
- Changes to system hardware, firmware, or software without the organization's knowledge, instruction, or consent;
- Violations of acceptable usage policies;
- Defacement or redirection of (insert company name here) websites;
- Breach of confidentiality;
- Incorrect disposal of documents, disks, or other media containing confidential information.

Policy Statement

This Incident Response Plan includes the following elements:

- Defined roles and responsibilities of individuals and departments in contributing to (insert company name here) incident response process;
- Definitions of cyber incident types and a classification scheme to translate observed facts into types;
- Requirements for reporting for every incident type listed;
- Instructions for the initial reaction and triage of incidents;
- Instructions for prioritizing and validating the incident;
- Instructions for maintaining the integrity of information and systems;
- Instructions for storing and securing evidence;
- Documentation requirements and storage procedures;
- Guidance on how to use data from incidents to reassess risk, evaluate and appropriately implement additional controls;
- Advice on how to measure the success of the Incident Response Team to continue to develop and refine response procedures;

- Instructions for sharing threat-related data with the information security/incident response community.

Roles and Responsibilities

Different systems, people, lines of business, and dangers can all impact the composition of the team needed to resolve a problem, as each information security-related incident is unique.

The Incident Response Team is in charge of putting the strategy into action and seeing that the issue(s) is resolved. This approach will apply to all employees, vendors, contractors, agents, and others who do business with (insert company name here).

Any of the following personnel and/or function groups (either in-house or outsourced) can be used to investigate, remediate, and close events successfully.

Executive Sponsor

- Oversees the overall IR process and any related programs.
- Monitors progress of response to declared incidents.
- Advocates for incident response training or appropriate external resources to assist the organization with processing incidents.
- Provides updates to Executive Management and/or Board of Directors in each meeting, which includes but is not limited to the number of incidents occurring, the results of the escalated incidents, lessons learned, etc.
- Raises classification of the incident to Crisis level.

Incident Response Coordinator

- Activates the plan and contacts members of the Incident Response Team.
- Determines which management team members are to be involved in the investigation and response process.
- Coordinates incident response among Incident Response Team members and impacted business units.
- As needed, organizes and runs periodic meetings to finish investigative, analytical, containment, and recovery operations.

- Authorizes immediate network actions to counter or mitigate threats. Some activities may avoid the typical change control process, so adequate change control documentation needs to be added after the incident.
- Assists the Incident Response Team and the Executive Sponsor as a liaison.
- Prepares a report of the occurrence and the steps taken to resolve it.

Information Technology

- Reports and increases awareness about Events or Incidents;
- Leads response from a technical standpoint and identifies third-party specialists for additional assistance;
- Takes charge of blocking traffic, isolating machines, or disabling accounts to counter threats and mitigate risks;
- Evaluates the forensics team to ensure technical expertise is aligned with the event's specific requirements;
- Oversees and manages all activities around maintaining and/or restoring confidentiality, integrity, and availability of data and systems;
- Ensures information and evidence integrity from gathering data to a chain of custody and preservation of forensic data;
- Identifies indicators of compromise (IOC);
- Identifies and executes options to further search for activity on the network.

Legal

- Ensures that all measures taken observe legal and regulatory standards, such as the right to privacy, paperwork obligations, and evidence preservation.
- Provides advice on problems relating to the privacy of customer and employee information.
- Assists the Marketing department in communication with affected parties.

Human Resources, Communication, and Insurance

- Coordinates efforts if one or more employees are involved in the incident;

- Provides consultancy for company-wide communication;
- Acts as a liaison between (insert company name here) and its cyber insurance provider.

Risk Management, Compliance, and Audit

- Ensures compliance with state laws and standards;
- Is the primary point of contact and maintains regular communication with regulatory agencies;
- Reviews systems, coordinates, and performs appropriate audit evaluations to ensure compliance with information security policy and controls;
- Provides updates to the Audit Committee and/or the Board of Directors when necessary.

Members of the Incident Response Team

(insert company name here)'s Incident Response Team is comprised of:

- (insert Incident Response Team members here with full names and job titles)

2. INCIDENT DEFINITION AND CLASSIFICATION

Incident Definition

All events and incidents will be tracked via a ticketing system or alternative tracking system so that every situation will have a unique number.

All events and incidents will be classified using the following classification scheme:

- Investigation – It refers to any anomaly of a network, system, or hosts that is still analyzed by Information Technology. Investigations will be open for a limited period of a maximum of 24 hours and be escalated as an incident or event, depending on the outcome of the initial analysis.
- Event – It refers to an attack, whether in progress or already completed. Initial facts such as source and destination may be known, but the event is likely still under investigation. An event does not pose a significant threat to the organization due to technical, procedural, or human controls in place. Events may be closed as such or when determined to be an explained anomaly on the network or system(s) in question.
- Incident – It refers to an event or investigation that has been determined to be exploiting a weakness in technical, procedural, or human control. Incidents have caused or have the potential to drive financial, reputational, compliance, operational or other damage to (insert company name here). Incidents will be designated based on the calendar year and number declared. For example, the first incident of 2021 would be given 2021-01, followed by 2021-02, and so on.
- Crisis – It refers to any of the following definitions and will result in enacting the Crisis Management Plan:
 - An incident that has significant media or social media attention;
 - An incident that involves unauthorized access, destruction, or loss of more than 100 records;
 - An incident that results in significant information technology outage to the extent that business processes are operating in a degraded state or not functioning at all.

Incident Type	Impact	Example
Crisis	Critical	• More than 50 workstations or 100 records affected • Loss of connectivity to a data center
Incident	High	• Single server compromised • Compromise of an administrative account
	Moderate	• Web defacement on a non-critical public website • Spear phishing attack • Compromise of a user-level account
Event	Low	• Virus detection and successful automatic removal • Failed brute force attack
Investigation	Undetermined	• Any

Reporting

The reporting obligations will vary depending on the type of occurrence.

Analysts who are gathering information for investigations will keep notes. Logs, screenshots, and analyst notes will be logged in a ticketing system. Additional documentation will be added as the investigation progresses to an event or as long as the investigation is still underway. The fact that the incident has progressed to an event, as well as the date, time, and authority involved, must be documented.

Incidents will also include who and when the inquiry or occurrence was upgraded to incident status. An incident number must be assigned to the incident, and documentation will be moved and tracked in the primary incident response database.

User access rights will be restricted to limit access only to the users whose activity is absolutely necessary. Crisis events can continue to be tracked in the IR database.

Internal Notification

The Executive Sponsor must be notified within 24 hours of an incident being declared. Unless otherwise specified, The Executive Sponsor will receive updates every 48 hours at the very least. More frequent updates will be required during a crisis, and they must be initiated every four hours.

Investigations and Events will be presented in weekly or monthly reports.

The IT department and/or Incident Response Team will get incident updates from the Incident Response Coordinator.

The Executive Sponsor will notify Executive Management, as appropriate, in the event of a major, systematic assault, a considerable loss of cash, or harm to customer information.

Notification to Regulatory and Law Enforcement Agencies

(insert company name here)'s Risk Management team will notify law enforcement if criminal activity is suspected. The Team will also be responsible for following any applicable Federal, State, or local legal requirements relating to the notification of law enforcement.

(insert company name here) will initiate an investigation of an incident involving unauthorized access or usage of sensitive customer or employee information that could result in substantial harm or inconvenience when it becomes aware of it, without unreasonable delay.

Affected Customers

If (insert company name here) can determine from logs or other data precisely whose personally identifiable information (PII) has been improperly accessed or the company has reasons to believe that misuse of that personal information has occurred or may occur, it will notify only those people.

If a group of files has been accessed improperly and (insert company name here) is unable to identify whose personally identifiable information has been accessed or management believes that misuse of the information contained in the group of files is reasonably possible, (insert company name here) will notify all individuals in the group.

Content of Customer Notice

(insert company name here) can delay the notification required by this section if a law enforcement agency determines that the notification will impede a criminal investigation.

The notification shall be made without delay after the law enforcement agency determines that it will not compromise the investigation.

The notice to customers must, at a minimum, contain the following information:

- A description of the incident in general terms;
- What information was the subject of unauthorized access or used when this is known;
- A telephone number that customers can call for further information and assistance;
- A reminder that customers need to remain vigilant over the next 12 to 24 months;
- Clear instructions for customers who need to report incidents of suspected identity theft;
- A brief description of (insert company name here)'s efforts to protect customers' information.

(This isn't an exhaustive list. Insert additional elements based on your company's specific activity.)

This notification will be delivered by phone, mail, or electronic mail depending on how each customer has agreed to receive communications from (insert company name here).

Incident Lifecycle

All events and incidents will go through the investigation phase. Based on facts known immediately, a decision can be made to escalate the situation into the Event or Incident stage.

Initial notification can come from a number of different sources, including internally from a human source (possible privilege misuse), externally from a human source, or internally from a technical source (SIEM, firewall, IDS/IPS). These sources will be funneled into the ticketing system to establish the initial documentation repository for what is known about the scenario.

Investigations must not exceed 24 hours. At the end of the 24 hours or as the situation escalates to an Event or Incident, execution of any initial actions to prevent further loss of data or spread of malicious logic must occur.

The designated Incident Response Coordinator must coordinate and agree with all the actions taken as part of the Incident Response Plan. Events and Incidents can stay open for longer periods and must be evaluated for closure on a weekly basis.

Prioritization

Depending on the sort of event, specific help from IT and other departments will be required. Requests for assistance in the event of a declared and marked incident shall take precedence over ordinary activity.

Planned events and implementations will be examined to see if incident actions must take precedence on a case-by-case basis.

Evidence

Collecting evidence will be done in a manner that assumes the incident will go to trial. This is especially true when the perpetrator is believed to be an insider such as an employee, vendor, or customer.

Investigations on incidents like malware, denial of service, or web defacement will also proceed with the same care until the Incident Response Coordinator designates otherwise.

Information Sharing

Company proprietary data must not be shared under any circumstance.

(insert company name here) may choose to share threat intelligence information about incidents. Each case will be examined on its own merits, with the Incident Response Team and the Executive Sponsor making the final decision on whether to share threat information, how to share it, and with whom to share it.

When (insert company name here) chooses to share information, data will be anonymized. Under no circumstance will the following information be released without first being anonymized:

- Personally Identifiable Information;
- Email addresses of customers or employees;
- IP addresses;
- Internal system hostnames.

(This isn't an exhaustive list. Insert additional elements based on your company's specific activity.)

3. INCIDENT RESPONSE TESTING

Lessons Learned

The Incident Response Team will perform a follow-up analysis after an incident has been fully resolved and all systems have been restored to normal. The team or appointed individuals will invite all parties involved in managing the incident to discuss the response. During these meetings, existing procedures will be evaluated and modified, if necessary.

The Incident Response Team will finalize the “Incident Response Report” and distribute copies to all appropriate departments and senior staff.

Tabletop Exercises

(insert company name here) will perform tabletop exercises with individuals that would experience or be part of an incident or investigation annually.

The tabletop exercises will emulate real-life situations (e.g. ransomware) to gain an understanding of whether additional training needs to be provided or if updates to the plan are needed.

GLOSSARY

Attack: Any attack, via cyberspace, targeting an enterprise's use of cyberspace for the purpose of disrupting, disabling, destroying, or maliciously controlling a computing environment or infrastructure; destroying the integrity of the data or stealing controlled information.

Breach: The unauthorized movement or disclosure of sensitive information to a party, usually outside the organization, that is not authorized to have or see the information.

Incident Response: The process of preparing for, identifying, responding to, and recovering from incidents to control and limit the adverse impact on operations.

Incident Response Plan (IRP): A document, which establishes specific procedures for detecting, responding, mitigating, and recovering from incidents affecting an organization's information systems.

Incident Response Team: A group of key people within an organization who are responsible for responding to computer security-related incidents.

Personally identifiable information (PII): Information that can be used to distinguish or trace the identity of an individual (e.g., name, social security number, biometric records, etc.) alone, or when combined with other personal or identifying information that is linked or linkable to a specific individual (e.g., date and place of birth, mother's maiden name, etc.).

PLAN MAINTENANCE / DISTRIBUTION

This Incident Response Plan will be updated as needed and will be reviewed and tested annually.

This document will be readily available to all Incident Response Core and Support Team members. In addition, each member of the Incident Response Team, management team, and supervisors will keep an additional copy of the current version in case of emergency or the inability to access the electronic repository.